The Sr. Phishermen's Intrusion Report #2

Table of Contents

Table of Contents **0**
Mitigating Measures **1**
Active Directory 1
Website 1
Label Printer 2
Warehouse Management System 2
Database 3
Attacks **4**
Default Credential Attempts 4
Successful AD Computer Creation 5
Conclusion **7**

Mitigating Measures

Active Directory

1. Reduced cached credential storage to prevent credential theft
2. Hardened NTLM authentication (set LmCompatibilityLevel to 5)
3. Enforced SMB signing to mitigate NTLM relay attacks
4. Reviewed and validated domain user accounts for legitimacy
5. Removed Domain Users group from Domain Admins group

Website

1. Added password hashing for new registrations and password changes
2. Updated SQL queries to use parameterized statements
3. Added allowlist for dynamic lookup keys in get_user_by to prevent arbitrary column injection
4. Changed default user creation path to non-admin
5. Removed automatic admin promotion from login_required decorator
6. Added @login_required protection on /get_payment_info endpoint
7. Disabled Flask debug mode

8. Centralized config into environment file
9. Removed overly-permissive elevated-user permissions in /etc/sudoers

Label Printer

1. Sanitize untrusted JSON fields before injection into ZPL
2. Switched placeholder substitution from regex-based -replace to deterministic string .Replace(...)
3. Replaced shell execution with Java's File.write(), preventing command injection
4. Added a barcode format validation and path traversal check to prevent path traversal vulnerabilities
5. Disabled Guest account to prevent unauthenticated access
6. Hardened NTLM authentication (fixed LmCompatibilityLevel from 0 to 5)
7. Identified and terminated suspicious service listening on port 1337
8. Restricted SMB share access to specific domain group (WarehouseUsers)
9. Removed overly permissive NTFS permissions (eliminated BUILTIN\Users access)

Warehouse Management System

1. Updated SQL queries to use parameterized statements
2. Centralized config into environment file

3. Removed malicious cron job resetting root password (chpasswd backdoor)

Database

1. Detected and removed tampered /bin/nc binary used for deception/persistence

Attacks

Default Credential Attempts

Our analysts were alerted to anomalous behavior in `/var/log/auth.log` across selected Linux systems and correlated repeated failed SSH authentication attempts. By tracking the username, source IP, timestamp, and failure frequency across multiple hosts, this module identifies brute-force attempts and default-credential abuse while filtering out benign failures.

Between **`Apr 25 08:09:51`** and **`Apr 25 09:02:15`**, Red Team attempted to access our systems using default credentials and previously known malicious usernames. The attackers attempted logins using accounts such as **`cdc`**, **`scrat`**, **`john.leguizamo`**, and **`root`**, all coming from a small set of IP addresses. The pattern of username rotation and timing is consistent with the behavior of the **isu-cdc-autopwn** brute-force script.

Because different machines were configured with slightly different time zones, some events appear with timestamps, but these correlate directly with the same attack window.

Below is a representative sample of our log

```
2026-04-25T03:30:00.702052+00:00 wms sshd[25531]: Failed password for invalid user jacqueline.elliott from 12.110.242.61 port 47304 ssh2
2026-04-25T03:35:01.650902+00:00 wms sshd[25549]: Failed password for invalid user jacqueline.elliott from 68.32.254.50 port 40368 ssh2
2026-04-25T03:40:00.901350+00:00 wms sshd[25564]: Failed password for invalid user jennifer.freeman from 12.110.242.62 port 37372 ssh2
2026-04-25T03:45:00.921607+00:00 wms sshd[25581]: Failed password for invalid user jennifer.freeman from 68.32.254.50 port 46174 ssh2
2026-04-25T03:50:00.706551+00:00 wms sshd[25598]: Failed password for invalid user christy.davis from 12.110.242.63 port 33106 ssh2
2026-04-25T03:55:00.689666+00:00 wms sshd[25621]: Failed password for invalid user jennifer.freeman from 68.32.254.50 port 53396 ssh2
2026-04-25T04:00:00.756473+00:00 wms sshd[25641]: Failed password for invalid user jennifer.freeman from 12.110.242.64 port 44786 ssh2
2026-04-25T04:05:00.242586+00:00 wms sshd[25689]: Failed password for invalid user jennifer.freeman from 68.32.254.50 port 42720 ssh2
2026-04-25T04:10:00.424832+00:00 wms sshd[25709]: Failed password for invalid user christy.davis from 12.110.242.65 port 43438 ssh2
2026-04-25T04:15:00.260963+00:00 wms sshd[25732]: Failed password for invalid user christy.davis from 68.32.254.50 port 45366 ssh2
2026-04-25T04:15:13.863827+00:00 wms sshd[25740]: Failed password for invalid user christy.davis from 68.32.254.50 port 41218 ssh2
2026-04-25T04:19:01.434781+00:00 wms sshd[25755]: Failed password for invalid user jennifer.freeman from 12.110.242.66 port 39250 ssh2
2026-04-25T04:19:13.385193+00:00 wms sshd[25759]: Failed password for invalid user christy.davis from 12.110.242.66 port 47328 ssh2
2026-04-25T04:20:00.493221+00:00 wms sshd[25762]: Failed password for invalid user christy.davis from 12.110.242.66 port 45112 ssh2
2026-04-25T04:21:43.634330+00:00 wms sshd[25775]: Failed password for invalid user jacqueline.elliott from 12.110.242.66 port 51828 ssh2
2026-04-25T04:25:00.704939+00:00 wms sshd[25783]: Failed password for invalid user christy.davis from 68.32.254.50 port 60884 ssh2
2026-04-25T04:26:56.356681+00:00 wms sshd[25796]: Failed password for invalid user jacqueline.elliott from 68.32.254.50 port 59702 ssh2
2026-04-25T04:27:17.893935+00:00 wms sshd[25799]: Failed password for invalid user christy.davis from 68.32.254.50 port 55272 ssh2
2026-04-25T13:01:54.392135+00:00 wms sshd[55376]: Failed password for invalid user cdc from 12.110.242.119 port 40828 ssh2
2026-04-25T13:03:04.966278+00:00 wms sshd[55391]: Failed password for invalid user cdc from 12.110.242.123 port 42542 ssh2
2026-04-25T13:13:09.865389+00:00 wms sshd[55629]: Failed password for invalid user cdc from 12.110.242.118 port 58828 ssh2
2026-04-25T13:14:56.534894+00:00 wms sshd[55636]: Failed password for invalid user cdc from 12.110.206.199 port 53010 ssh2
2026-04-25T13:35:35.148392+00:00 wms sshd[56126]: Failed password for invalid user root from 12.110.242.128 port 60100 ssh2
2026-04-25T13:35:37.599372+00:00 wms sshd[56128]: Failed password for invalid user cdc from 12.110.242.128 port 60112 ssh2
2026-04-25T13:35:37.865323+00:00 wms sshd[56131]: Failed password for invalid user john.leguizamo from 12.110.242.128 port 46456 ssh2
2026-04-25T13:45:53.624105+00:00 wms sshd[56326]: Failed password for invalid user cdc from 12.110.242.119 port 34444 ssh2
2026-04-25T13:45:54.147928+00:00 wms sshd[56329]: Failed password for invalid user cdc from 12.110.242.119 port 34456 ssh2
2026-04-25T13:45:54.154881+00:00 wms sshd[56324]: Failed password for invalid user cdc from 12.110.242.119 port 34430 ssh2
2026-04-25T13:48:42.257153+00:00 wms sshd[56344]: Failed password for invalid user root from 12.110.242.128 port 33768 ssh2
2026-04-25T13:48:43.946799+00:00 wms sshd[56349]: Failed password for invalid user john.leguizamo from 12.110.242.128 port 33776 ssh2
2026-04-25T13:48:44.071446+00:00 wms sshd[56346]: Failed password for invalid user cdc from 12.110.242.128 port 33774 ssh2
2026-04-25T14:07:19.978326+00:00 wms sshd[56734]: Failed password for invalid user cdc from 12.110.206.199 port 55570 ssh2
2026-04-25T14:45:26.000953+00:00 wms sshd[57571]: Failed password for invalid user john.leguizamo from 12.110.242.128 port 38016 ssh2
2026-04-25T14:45:27.977727+00:00 wms sshd[57573]: Failed password for invalid user andra.henderson from 12.110.242.128 port 53862 ssh2
2026-04-25T14:45:30.631361+00:00 wms sshd[57575]: Failed password for invalid user darren.williams from 12.110.242.128 port 53870 ssh2
2026-04-25T14:45:31.924008+00:00 wms sshd[57578]: Failed password for invalid user allison.hamilton from 12.110.242.128 port 53876 ssh2
2026-04-25T14:45:34.793698+00:00 wms sshd[57581]: Failed password for invalid user lori.petersen from 12.110.242.128 port 53882 ssh2
```

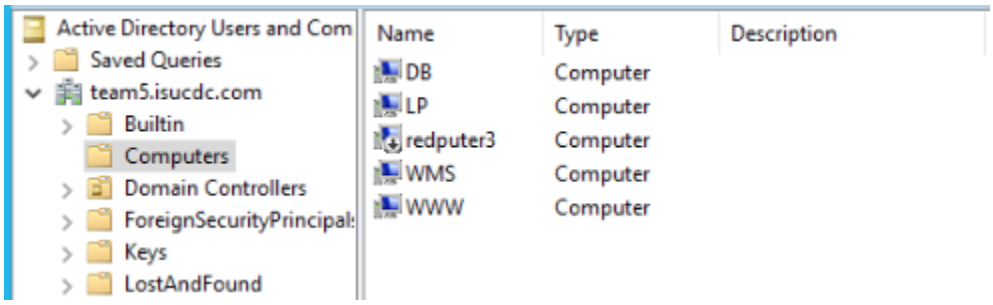
This attempt to gain access to our network had **no impact** on our operations.

Successful AD Computer Creation

During routine monitoring of Active Directory security logs, an unexpected computer account creation event was observed at **11:10 AM**. The activity was initially not detected by prior query attempts, but was later confirmed through direct inspection of the **Computers container in Active Directory Users and Computers (ADUC)** and correlated with domain controller security logs.

The event indicates that a non-admin or low-privileged identity was able to create a domain-joined computer object,

suggesting a potential misconfiguration in Active Directory delegation or machine account creation permissions.



To mitigate the incident, the computer was disabled and the Directory Service Machine Account Quota was set to 0.

Further incident response found no direct impact. As such, this attempt to gain access to our network had **no impact** on our operations.

Conclusion

Actions were taken to compromise our network; however, no actions allowed for the successful, impactful exploitation of our network.